

Enterprise Strategy & Reference Architecture: Securing Autonomous Agents & Non-Human Intelligence (NHI)

Document Control: Revision 2.0 (Updated September 10, 2026)

Target Readership: Fortune 100 CISOs, Chief AI Officers (CAIOs), Enterprise Security Architects

Authoritative Frameworks: CSA MAESTRO, OWASP Top 10 for Agentic Applications (2026 Official ASI01–ASI10), MITRE ATLAS

Document Typography: Calibri (Body: 11pt, H1: 18pt Bold, H2: 14pt Bold, H3: 12pt Semi-Bold)

1. Executive Summary & Core Paradigm Shift

Enterprise AI has transitioned from passive conversational interfaces to **autonomous, multi-agent systems**. Unlike legacy predictive or generative models, agents possess operational agency: they maintain execution state, decompose goals, invoke enterprise APIs, execute terminal commands, and communicate across network boundaries.

The Deterministic Enforcement Axiom

- **The Reality:** Large Language Models are inherently probabilistic. They cannot provide mathematical or cryptographic guarantees against jailbreaks, deceptive alignment, task drift, or goal-seeking reward bypasses.
- **The Governance Mandate:** **Never rely on an agent's internal alignment, system prompt instructions, or natural language guardrails as an authoritative security boundary.** Security policies cannot be negotiated via natural language.
- **The Architectural Rule:** Enclose probabilistic agents within **deterministic, non-bypassable controls** (hardware microVM isolation, cryptographically signed workload identities, capability-based tool proxies, and strict network egress firewalls). Areas where deterministic controls cannot be applied must be classified as unverified attack surfaces subject to continuous behavioral monitoring and out-of-band circuit breakers.

2. Attack Surface Mapping: The Triple-Framework Alignment

Following OWASP's formalization of the **Top 10 for Agentic Applications (ASI01–ASI10)** and recent CISA/NSA threat advisories, enterprise defense must align across three synchronized standards:

1. **CSA MAESTRO:** Deconstructs the agentic operational stack into 7 functional architectural layers.
2. **OWASP Top 10 for Agentic Applications (2026):** Catalogs structural vulnerabilities unique to autonomous systems with tool access, delegated identities, and multi-step execution paths.
3. **MITRE ATLAS:** Classifies adversary Tactics, Techniques, and Procedures (TTPs) targeting AI pipelines.

MAESTRO Layer	OWASP Threat Alignment (ASI Standard)	MITRE ATLAS Technique	Enterprise Security Objective
1. Model (Inbound & Outbound)	ASI04: Agentic Supply Chain Vulnerabilities	AML.T0010: ML Supply Chain Compromise	Verify model weight signatures, enforce SBOM/AIBOM integrity, and detect outbound bulk scraping/model theft.
	LLM05 / LLM10: Model Theft & Extraction	AML.T0031: Exfiltration via ML API (Industrial Distillation)	
2. Agent (Planning) & State	ASI01: Agent Goal Hijack	AML.T0040: ML Model Evasion	Confine planning loops, detect goal deviation, and prevent reward-seeking shortcuts.
	ASI10: Rogue Agents	AML.T0051: LLM Prompt Injection (Indirect)	

3. Environment & Memory	ASI06: Memory & Context Poisoning LLM06: Sensitive Info Disclosure	AML.T0035: LLM Data Poisoning AML.T0031: Exfiltration via ML API	Enforce write-validation on long-term memory, isolate context windows, and prevent cross-session poisoning.
4. Security & Governance	ASI09: Human-Agent Trust Exploitation LLM07: System Prompt Leakage	AML.T0043: Adversarial Data Injection AML.T0029: Denial of Service	Deploy asymmetric out-of-band overseers, activation-steering shims, and cognitive tripwires.
5. Tools & Skills (MCP)	ASI02: Tool Misuse & Exploitation ASI03: Identity & Privilege Abuse	AML.T0053: LLM Plugin / MCP Compromise AML.T0048: Tool Misuse	Enforce capability-based access tokens, JSON schema typing, and continuous proxy vulnerability patching.

6. Runtime Execution	ASI05: Unexpected Code Execution (RCE)	AML.T0047: Sandbox Escape	Guarantee hardware-level kernel isolation (microVMs) and patch local pre-execution agent plumbing (CLI).
	LLM08: Excessive Agency	AML.T0042: Resource Flooding	
7. Operations & Orchestration	ASI07: Insecure Inter-Agent Communication	AML.T0015: Lateral Movement	Implement mTLS agent-to-agent authentication, capability attenuation, and immutable WORM audit trails.
	ASI08: Cascading Failures	AML.T0037: Model Inversion	

3. Layer-by-Layer Strategy & Tooling Reference Matrix

To maximize capital efficiency, Fortune 100 enterprises must **leverage existing brownfield enterprise platforms** before procuring specialized point solutions.

MAESTRO Layer	Primary Attack Vectors & Real-World Precedents	Brownfield Enterprise Leverage	Frontier AI Security Tooling

1. Model	Inbound: Weight backdoors. Outbound: Industrial-scale distillation (e.g., September 2026 NSA/CISA/FBI joint advisory naming six adversarial firms systematically siphoning frontier model weights via bulk API transfer stations).	CrowdStrike Falcon / Microsoft Defender for Cloud: Compute posture. F5 / Cloudflare / Akamai: API rate limiting, bot detection, behavioral egress fingerprinting.	Hugging Face ModelScan: Safe tensor serialization. Sigstore / Cosign: AIBOM signing. Dynamic Honeypotting: Quietly degrade/poison responses to suspect distillation scrapers.
2. Agent & State	Goal hijack (ASI01), indirect prompt injection through web/repo data, planning loop drift.	Okta / Microsoft Entra ID: Ephemeral machine workload identities. CyberArk / HashiCorp Vault: Dynamic credential rotation.	Aembit / Oasis Security: Non-Human Identity (NHI) governance. SPIFFE / SPIRE: Cryptographic mTLS workload identity.

3. Environment & Memory	Persistent memory poisoning (ASIO6), RAG retrieval contamination, cross-tenant vector bleeding.	Symantec DLP / Microsoft Purview / Netskope: Extended to intercept RAG pipelines, vector embeddings, and prompt egress.	Arize Phoenix / OpenLineage: Data-lineage validation. Cryptographic Memory Signatures: Enforce write-validation gates on vector DBs (Pinecone, Qdrant).
4. Security & Governance	Deceptive planning, hidden rationalizations, unfaithful scratchpads.	Splunk / Datadog: SIEM event correlation. Palo Alto Networks / Zscaler: In-line API gateway egress inspection.	Asymmetric Overseer Models: Lightweight LLMs auditing scratchpads. NeMo Guardrails / Lakera Guard: Real-time semantic gating.
5. Tools & Skills (MCP)	Unauthorized tool invocation, auth bypasses in tool gateways (e.g., CVE-2026-5982 2 in LiteLLM added to CISA KEV; CVSS 8.8).	Kong / Apigee / MuleSoft: Gateway schema enforcement. Open Policy Agent (OPA) / AWS Verified Permissions:	MCP Tool Proxies: Model Context Protocol schema interceptors. Mandatory Patch SLAs: Vulnerability scanning on AI gateway proxies.

		Cedar policy checks.	
6. Runtime Execution	Zero-click execution via agent plumbing (e.g., GitSpawn <code>.git/config</code> abusing <code>core.fsmonitor</code>), container breakout.	VMware ESXi / KVM: Hypervisor infrastructure. CrowdStrike Falcon Sensor / Defender for Endpoint: Workstation CLI monitoring.	AWS Firecracker microVMs: Hardware-isolated guest kernels. Dev Workstation Pre-Exec Hooks: Disabling ambient git configs (<code>core.fsmonitor=false</code>).
7. Operations & Orchestration	Inter-agent privilege escalation (ASI07), unmonitored agent collusion, cascading failures.	ServiceNow: Human-in-the-loop (HITL) escalations. Dynatrace / AppDynamics: Distributed APM transaction tracing.	Langfuse / LangSmith / OpenLLMetry: Telemetry & spans. WORM Storage: Immutable cryptographic agent audit trails.

4. Agentic Communications, Data Provenance, and Non-Human Identity (NHI)

When Agent A delegates tasks to Agent B, perimeter assumptions fail. Systems must enforce cryptographic chain-of-custody across all inter-agent traffic:

- **Cryptographic Identity (No Ambient Authority):** Every agent runtime receives a transient workload certificate using **SPIFFE/SPIRE** or **Okta Workload Identity Federation**. Static API keys stored in environment variables are strictly prohibited.
- **Capability-Based Attenuation:** When delegating to sub-agents, permissions must be strictly narrow. Tokens must be cryptographically attenuated (e.g., Macaroons) containing single-use action scopes with a Time-to-Live (TTL) under 120 seconds.
- **Data Provenance & MCP Signatures:** All tool outputs passed into an agent's context window must be signed with a SHA-256 HMAC by the enterprise tool proxy. If an agent hallucinates, forges, or alters a database response in its scratchpad, the signature check fails and halts the execution pipeline.
- **AI Gateway Patch Governance:** Deploying an MCP proxy is an asset liability, not a static control. Organizations must mandate a **7-day critical patch SLA** for all AI proxy layers (e.g., LiteLLM, LangGraph Server) to prevent unauthenticated access to attached enterprise tools.

5. Architectural Blueprint: The Enterprise Agent Gateway

To prevent bypasses like **GitSpawn**—where an innocent-looking `git status` or `git diff` triggered arbitrary attacker code before workspace approval—the Risk Evaluation Engine removes "read operations" from auto-approval lists if they invoke external subshells or environment-configured tooling.

[Ingress / Prompt Layer] | User / API Call passes through Enterprise DLP (Purview / Netskope) ▼ [Agent Reasoning Core (Untrusted)] | Agent generates CoT Scratchpad + Tool Payload ▼ [Revised Risk Evaluation Engine] |— SAFE INTERNAL READ (In-memory AST, isolated file buffer) —► Pass-Through |— RISKY / SUBPROCESS ACTION (Git, Shell, MCP tool, Network) | ▼ Route to [Asymmetric Overseer Model] |— Verify Intent Alignment against Root Goal |— Check for Reward Hacking / Deceptive Obfuscation |— Sanitize Subprocess Environment Flags (e.g., `-c core.fsmonitor=false`) | (Approved) ▼ [Tool & Identity Proxy (LiteLLM / Kong / OPA)] | Enforce Patched Gateway SLA (e.g., CVE-2026-59822 mitigation) | Validate SPIFFE mTLS Workload Certificate & Capability Token ▼ [Deterministic Isolation Sandbox] | Developer Edge: Pre-execution git hooks & workspace jails | Cloud/Backend: AWS Firecracker microVM (Dedicated Guest Kernel) | Ephemeral Storage & Default-Deny Network Egress Proxy

6. Enterprise Phased Implementation Roadmap

Phase 1: Discovery, NHI Inventory & Outbound Protection (Weeks 1–4)

- **Audit Shadow Agent Workflows:** Deploy EDR sensors (CrowdStrike/Defender) to catalog local CLI agents (Claude Code, Cursor, Aider, Windsurf) across developer workstations.

- **Outbound Distillation Defense:** Implement API usage anomaly models on external enterprise endpoints (Cloudflare/Akamai). Detect high-frequency, systematically structured prompt extraction campaigns and route suspect accounts to degraded/tarpit responses.
- **Inventory Non-Human Identities (NHI):** Deprecate all static API keys in favor of short-lived (1-hour max) workload credentials.
- **Extend Enterprise DLP:** Apply regex and embedding classifiers to RAG vector ingestion pipelines and outbound prompt streams.

Phase 2: Boundary Enforcement & Developer Edge Hardening (Weeks 5–12)

- **Patch the Developer Edge:** Remediate CLI agent plumbing vulnerabilities (such as GitSpawn). Force enterprise global git configs via MDM (`git config --global core.fsmonitor false`) and mandate containerized CLI sandboxes for local agent execution.
- **Cloud Sandboxing:** Require all server-side autonomous agent code execution to run inside ephemeral AWS Firecracker microVMs or gVisor runtimes.
- **Deploy Deterministic MCP Proxies:** Route all Model Context Protocol calls through hardened, vulnerability-scanned proxies (enforcing a 7-day patch SLA against CISA KEV entries).
- **Egress Lockdown:** Default-deny all network egress from agent sandboxes, allowing only explicitly allowlisted enterprise APIs.

Phase 3: Cognitive Telemetry & Continuous Ingestion (Weeks 13+)

- **Deploy Asymmetric Overseers:** Implement risk-gated secondary inspection on agent intermediate scratchpads for all high-privilege tool execution paths.
- **Memory Write Gates (ASI06):** Enforce human approval or overseer validation before an agent can write to persistent long-term vector memory stores.
- **Automated Threat Intelligence Ingestion:** Integrate an automated monitoring agent that ingests updates from MITRE ATLAS, the OWASP Agentic AI Project (ASI series), and national cybersecurity advisories, automatically opening pull requests to update internal detection rules, git flags, and tool schemas.